

POLITIQUE DE SÉCURITÉ DE L'INFORMATION

Infrastructure SIEM / IDS — Projet CYNA-IT

Version	1.0	Date d'application	28/06/2026
Rédacteur	Renaud Nassou Orou — Responsable Sécurité	Référentiels	ISO/IEC 27001 · ANSSI · RGPD
Périmètre	Infrastructure SIEM / IDS (Wazuh, Suricata, Graylog, Grafana, Gitea)	Diffusion	Interne

La présente Politique de Sécurité de l'Information (PSI) formalise l'ensemble des règles, mesures techniques et dispositions organisationnelles garantissant la confidentialité, l'intégrité et la disponibilité du système d'information mis en œuvre dans le cadre du projet CYNA-IT. Elle s'appuie sur les bonnes pratiques de l'ANSSI, sur la norme ISO/IEC 27001 et, s'agissant des données à caractère personnel, sur le Règlement Général sur la Protection des Données (RGPD).

1. Objet et contexte

Le projet CYNA-IT repose sur une architecture de supervision de sécurité centralisée. Un manager Wazuh hébergé sur le serveur **SRV-SECU-GENEVE** collecte et corrèle les événements remontés par les agents déployés sur les machines surveillées (**SRV-SECU-PARIS**, **Agent-ansible**, **Agent-paris** sous Kali, **Agent-win-test** sous Windows). La détection réseau est assurée par Suricata, la centralisation des journaux par Graylog et la visualisation par Grafana. La présente politique définit les exigences de sécurité applicables à cet ensemble.

2. Périmètre d'application

La politique s'applique à l'intégralité des ressources du projet, à savoir :

- les serveurs de sécurité (manager SIEM, sonde IDS) et leurs systèmes d'exploitation ;
- les machines surveillées Linux et Windows, ainsi que les agents Wazuh associés ;
- les équipements et segments réseau (VLAN d'administration, de production, DevOps) ;
- les applications internes : Wazuh, Suricata, Graylog, Grafana et la forge Gitea ;
- les comptes utilisateurs, comptes d'administration et comptes de service ;
- les données traitées, stockées ou transmises par ces composants (journaux, métadonnées).

3. Rôles et responsabilités

- **Responsable sécurité** : définit, maintient et fait appliquer la présente politique, supervise les alertes Wazuh/Suricata et pilote la réponse aux incidents ;
- **Administrateurs systèmes et réseau** : appliquent les mesures de durcissement, gèrent les comptes, les correctifs et les sauvegardes ;
- **Utilisateurs** : respectent les règles d'accès et signalent tout comportement anormal ;
- **Délégué à la protection des données (DPO / point de contact RGPD)** : veille à la conformité des traitements et instruit les demandes d'exercice des droits.

4. Contrôle d'accès

- application stricte du principe du moindre privilège ;
- comptes d'administration nominatifs, réservés aux personnes habilitées ;
- accès SSH par clés exclusivement, restreint au VLAN d'administration ; désactivation de l'authentification SSH par mot de passe et de la connexion *root* directe ;
- limitation du nombre de tentatives d'authentification (paramètre `MaxAuthTries`, `fail2ban`) ;
- segmentation du réseau afin de limiter les déplacements latéraux entre environnements ;
- désactivation immédiate des comptes lors d'un départ ou d'une inactivité prolongée.

5. Gestion des identités et des authentifications

- comptes nominatifs obligatoires ; comptes de service non interactifs et cloisonnés ;
- authentification forte (MFA) recommandée pour les accès aux interfaces sensibles (Wazuh Dashboard, Grafana, Gitea) ;
- politique de mots de passe robuste : longueur minimale, complexité, expiration et historique ;
- rotation régulière des clés SSH, jetons et secrets applicatifs ;
- journalisation systématique des connexions, réussies comme échouées.

6. Sécurité du réseau

- pare-feu en politique restrictive par défaut (*deny-all* + liste d'autorisation) ;
- ouverture limitée aux seuls flux strictement nécessaires au fonctionnement des services ;
- détection des intrusions et des anomalies réseau par Suricata (IDS/IPS) ;
- détection des scans réseau, des tentatives de force brute et des comportements suspects ;
- cloisonnement des environnements (production / administration / DevOps) ;
- réduction de la surface d'attaque : fermeture ou filtrage des services exposés non requis (double service SSH, interface Gitea), conformément aux constats des tests de sécurité.

7. Chiffrement et protection des données

- chiffrement des communications via TLS 1.3 ; interdiction des protocoles obsolètes (SSL, TLS 1.0/1.1) ;
- exposition des interfaces web (Gitea, Grafana) en HTTPS uniquement ;
- chiffrement des disques (LUKS) sur les serveurs hébergeant des données sensibles ;
- protection des secrets (clés, mots de passe applicatifs) en coffre dédié, hors dépôts de code.

8. Journalisation et supervision

- centralisation des journaux dans Wazuh et Graylog ;
- collecte des journaux système, applicatifs, réseau et de sécurité (PAM, sshd, auditd, syslog) ;
- corrélation automatique des événements avec les alertes Suricata et la matrice MITRE ATT&CK ;
- durée de conservation des journaux : 90 jours minimum, sans collecte excessive ;
- tableaux de bord de supervision (Wazuh Dashboard, Grafana) consultés régulièrement.

9. Détection et réponse aux incidents

Les dispositifs de détection couvrent notamment les techniques observées lors des tests : découverte de services réseau (MITRE T1046) et tentatives d'authentification par devinette de mot de passe (MITRE T1110.001). En cas d'alerte, la procédure suivante s'applique :

- qualification et confinement de l'incident selon une procédure documentée ;
- notification immédiate du responsable sécurité pour toute alerte critique ;
- analyse post-incident (RCA) obligatoire et tracée ;
- mise à jour des règles Wazuh / Suricata à l'issue de chaque incident.

10. Gestion des vulnérabilités et des correctifs

- application régulière des mises à jour de sécurité des systèmes et applications ;
- activation du module de détection de vulnérabilités de Wazuh et des sources CVE associées ;
- vérification périodique des vulnérabilités et inventaire logiciel des agents ;
- correction prioritaire des CVE critiques selon leur niveau de sévérité.

11. Sauvegarde et continuité

- sauvegardes régulières et chiffrées des configurations et des données critiques ;
- tests de restauration réalisés à intervalles trimestriels ;
- stockage des sauvegardes des données critiques sur un emplacement distinct.

12. Conformité au Règlement Général sur la Protection des Données (RGPD)

L'infrastructure étant exploitée en France, les traitements de données à caractère personnel sont encadrés par le RGPD et la loi Informatique et Libertés.

12.1 Principes

Les traitements respectent les principes de licéité, loyauté et transparence, de limitation des finalités, de minimisation des données, d'exactitude, de limitation de la conservation et d'intégrité et de confidentialité.

12.2 Données concernées

Les outils de supervision (Wazuh, Suricata, Graylog) collectent des données techniques pouvant comporter des identifiants de connexion, des adresses IP, des journaux d'authentification et des actions réalisées sur les systèmes. **Aucune donnée sensible** (santé, opinions, biométrie) n'est traitée.

12.3 Base légale

- intérêt légitime : assurer la sécurité du système d'information ;
- obligation de sécurité des réseaux et systèmes et de prévention des incidents.

12.4 Mesures de protection

- pseudonymisation des données lorsque cela est techniquement possible ;
- chiffrement des communications (TLS 1.3) et accès limité aux seuls administrateurs habilités ;
- journalisation contrôlée et proportionnée, conservation limitée à 90 jours ;
- traitement et stockage internes, sans transfert des données à des tiers.

12.5 Droits des personnes

Toute personne concernée dispose d'un droit d'accès, de rectification, d'opposition et de limitation. Un point de contact interne (DPO ou responsable sécurité) est désigné pour instruire ces demandes.

12.6 Transferts et traçabilité

- aucun transfert de données à caractère personnel hors de l'Union européenne ;
- tenue d'un registre des traitements et documentation des mesures de sécurité ;
- procédure de notification des violations de données à la CNIL sous 72 heures.

13. Sensibilisation et formation

- sensibilisation des utilisateurs aux risques (hameçonnage, mots de passe, ingénierie sociale) ;
- information sur les bonnes pratiques d'usage des accès et des outils ;
- diffusion et rappel régulier de la présente politique.

14. Audit, révision et validation

- tests d'intrusion réalisés à intervalle régulier (au minimum annuel) ;
- audit de la configuration Wazuh / Suricata tous les six mois ;
- vérification périodique des règles de détection IDS/IPS ;
- révision de la politique à chaque évolution majeure de l'infrastructure.

Validation

Document approuvé par	Fonction	Date	Signature
Renaud Nassou Orou	Responsable Sécurité — Projet CYNA-IT	28/06/2026	